Maestría en Ciberseguridad



DIAGNÓSTICO DEL NIVEL DE CONOCIMIENTO SOBRE INGENIERÍA SOCIAL EN ENTORNOS FAMILIARES Y EMPRESARIALES

Instrumento de investigación aplicado — Entrega 1

Alumno: ElVigilante

Matrícula: ?

Materia: Delitos Cibernéticos

Docente: Dulce Vázquez Cano

Institución: UMAD Online Ingenieria en Ciberseguridad

Fecha de entrega: 27 de septiembre de 2026

1. Objetivo de la Encuesta

Este instrumento busca diagnosticar qué tanto conocen las técnicas de ingeniería social las personas de mi entorno familiar, académico, laboral y social. El foco está en ocho técnicas concretas que se han vuelto el vector de entrada más común en los incidentes de los últimos años: phishing, spear phishing, whaling, smishing, vishing, pretexting, tailgating y quishing. Además de medir reconocimiento, la encuesta indaga en la percepción de riesgo de cada persona y en si ya ha vivido —directa o indirectamente— alguno de estos ataques, para poder construir después un panorama comparativo entre distintos perfiles (estudiantes, empleados, directivos, amas de casa, empresarios, jubilados) y, con eso, proponer acciones de concientización que respondan a carencias reales y no a suposiciones.

La decisión de estratificar por ocupación y no solo por edad responde a algo que se discutió en el curso: el conocimiento técnico no necesariamente protege a quien lo tiene, porque la ingeniería social ataca el factor humano, no el sistema. Un directivo puede saber perfectamente qué es el phishing y aun así caer en un whaling bien dirigido, porque el ataque explota la urgencia y la autoridad, no un desconocimiento técnico. Por eso la encuesta separa "reconocer la técnica" de "percibirse vulnerable": son cosas distintas y ambas importan para el diagnóstico.

1.1 Consentimiento informado y aviso de privacidad

Antes de la primera pregunta, el formulario incluye un párrafo de consentimiento informado que se muestra de forma obligatoria: se explica que la participación es voluntaria y anónima, que no se pide nombre, correo ni ningún dato que permita identificar a la persona, y que las respuestas se usan únicamente con fines académicos dentro de esta materia. La opción de "Recopilar direcciones de correo electrónico" de Google Forms se dejó desactivada de manera deliberada para sostener esa promesa de anonimato en la práctica y no solo en el texto.

1.2 Estructura del instrumento y cierre

El cuestionario está dividido en cinco bloques temáticos (demografía, conocimiento general de ciberseguridad, reconocimiento de técnicas de ingeniería social, experiencia personal y percepción del riesgo), descritos con más detalle en la sección 3 de este documento. Al final se agradece al encuestado por su tiempo y se le deja una recomendación concreta y aplicable de inmediato —activar la verificación en dos pasos— para que la encuesta misma funcione ya como un primer gesto de concientización, sin esperar a la entrega final del curso.

2. Público Objetivo

El instrumento se dirige a personas mayores de edad de mi círculo familiar, académico, laboral y social, en su mayoría residentes de Mexicali, Baja California. Busco una muestra heterogénea que incluya estudiantes, empleados, directivos o gerentes, dueños de negocio, amas de casa y jubilados, con un rango amplio de edades y niveles educativos, para poder comparar el nivel de conocimiento de ingeniería social entre grupos poblacionales distintos, tal como lo pide la actividad.

Esta selección no es aleatoria en el sentido estadístico estricto —es una muestra por conveniencia, típica de un diagnóstico exploratorio como este— pero sí se diseñó para tener variedad real: al difundir la encuesta en un grupo académico de WhatsApp, en Microsoft Teams dentro de mi trabajo y por correo a toda la organización, se alcanzan simultáneamente perfiles muy distintos entre sí (desde amas de casa sin exposición técnica hasta personal de TI), lo cual es justo el contraste que el diagnóstico necesita para ser útil.

3. Metodología y Diseño del Instrumento

El instrumento se construyó en Google Forms por su facilidad de distribución, su exportación directa a Google Sheets/CSV y su compatibilidad con dispositivos móviles, que es como la mayoría de las personas de mi entorno va a contestarlo. Consta de 20 preguntas —dentro del rango de 15 a 20 que pide la actividad— organizadas en cinco bloques:

- Bloque A — Datos demográficos (5 preguntas): edad, ocupación, sector laboral, nivel educativo y horas de uso de internet. Permite segmentar después las respuestas por perfil.
- Bloque B — Conocimiento general de ciberseguridad (2 preguntas): qué tan familiarizada se siente la persona con el término y si conoce y usa la autenticación multifactor.
- Bloque C — Reconocimiento de técnicas de ingeniería social (8 preguntas): un escenario breve y realista por cada una de las ocho técnicas solicitadas (phishing, spear phishing, whaling, smishing, vishing, pretexting, tailgating y quishing), con opción múltiple de una sola respuesta correcta.
- Bloque D — Experiencia personal (2 preguntas): si la persona ha sido víctima de algún ataque de este tipo y, en su caso, de cuál.
- Bloque E — Percepción del riesgo (3 preguntas): qué tan vulnerable se percibe hoy, con qué frecuencia recibe mensajes sospechosos y qué medidas de protección usa actualmente.

3.1 Por qué estas preguntas y no otras

Cada pregunta del bloque C se redactó como un caso concreto ("recibes un mensaje de texto que dice que un paquete no pudo entregarse...") en lugar de pedir la definición de la técnica, porque lo que interesa medir no es si la persona memorizó un término, sino si sabría reconocer el ataque en el momento real en que ocurre, que es donde de verdad se decide si cae o no. Esta forma de preguntar también facilita el análisis estadístico posterior: cada reactivo tiene una única respuesta correcta y codificable, lo que permite calcular un porcentaje de aciertos por técnica y compararlo entre grupos de edad, ocupación o sector, sin depender de respuestas abiertas difíciles de clasificar.

Las preguntas de percepción de riesgo, en cambio, se dejaron con escalas de 1 a 5 y opciones cerradas de frecuencia, porque ahí no hay una respuesta correcta: lo que se busca es un dato comparable entre personas, no evaluar si alguien acertó o no. Esta separación entre preguntas de conocimiento (con respuesta correcta) y preguntas de percepción (sin ella) es, a mi parecer, la decisión metodológica más importante del diseño, porque evita mezclar dos cosas que miden fenómenos distintos: lo que la persona sabe y lo que la persona siente que sabe.

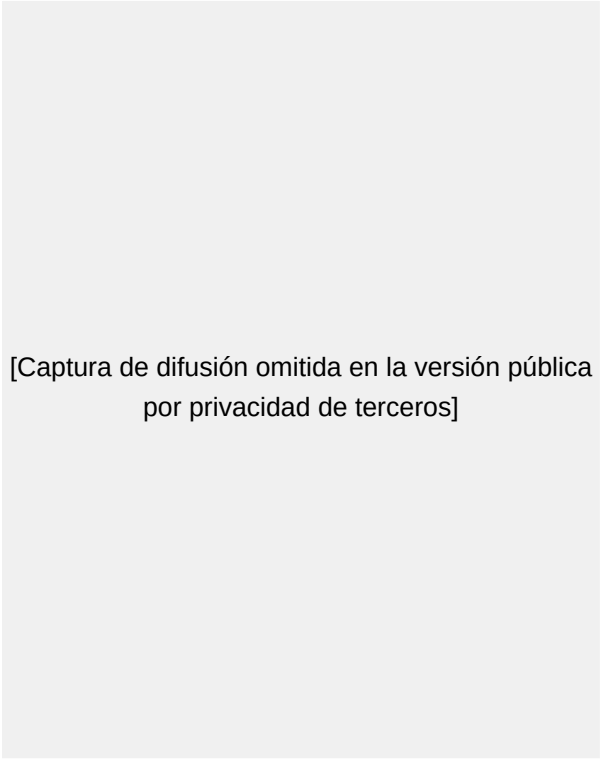
4. Link del Instrumento

https://docs.google.com/forms/d/e/1FAIpQLSfoshQlbPBUK44iCvzvUviEWpYX9YLxMRT8-3LQtrAzOGiHTA/viewform

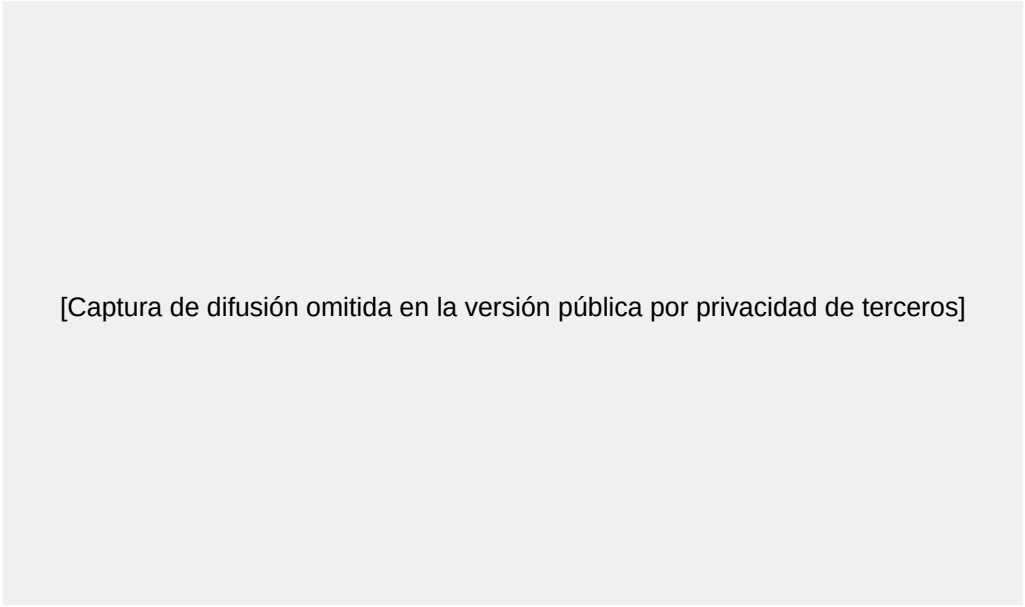
El formulario es de acceso público: no pide iniciar sesión ni solicita ningún permiso especial para responder, lo verifiqué abriéndolo yo mismo en una ventana de incógnito antes de compartirlo. Contiene las 20 preguntas distribuidas en los cinco bloques descritos arriba, precedidas por el aviso de privacidad y consentimiento informado.

4.1 Evidencia de Difusión

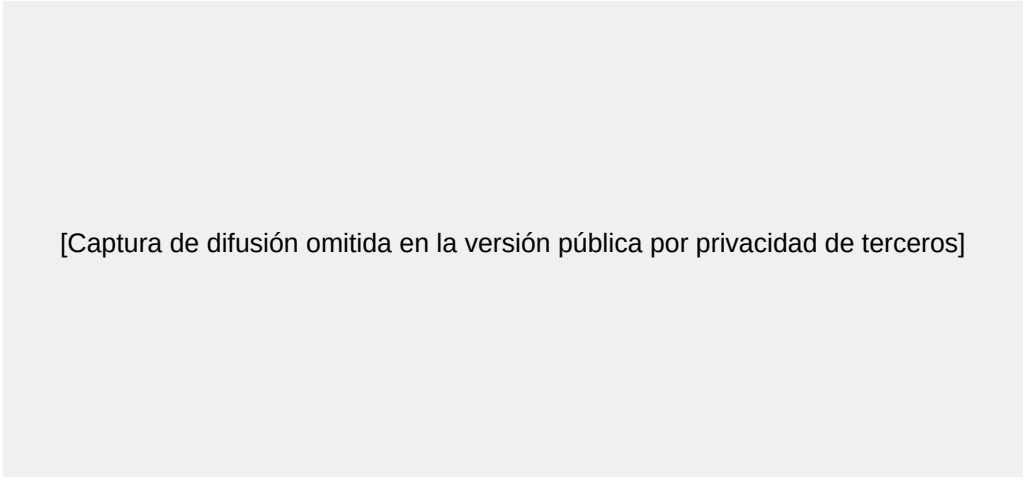
El instrumento se compartió en tres canales distintos, buscando llegar a perfiles poblacionales diferentes entre sí. Por privacidad, los nombres, fotos y números telefónicos de terceros que aparecían en las capturas originales fueron cubiertos antes de incluirlas aquí.



Difusión vía WhatsApp, grupo académico (datos de terceros cubiertos por privacidad).



Difusión vía Microsoft Teams, dentro de la empresa donde trabajo.



Difusión por correo electrónico a la lista general de la organización (376 destinatarios).

5. Análisis y Reflexión de los Hallazgos Esperados

Con base en lo revisado durante el curso, espero encontrar un conocimiento desigual entre los encuestados, fuertemente relacionado con la edad, el nivel educativo y la exposición laboral a temas tecnológicos. El phishing y, en menor medida, el vishing, deberían ser las técnicas más reconocidas por la mayoría de los participantes, simplemente porque son las que más se mencionan en medios y en advertencias bancarias. En contraste, espero que el pretexting, el tailgating y el quishing tengan los niveles más bajos de reconocimiento, no porque sean menos peligrosos, sino porque son términos que casi no circulan fuera de círculos técnicos —a diferencia del phishing, nadie te advierte del tailgating en la fila del banco.

También espero encontrar una brecha entre lo que la gente dice conocer y lo que realmente hace para protegerse. Es previsible que buena parte de los encuestados afirme "conocer" el phishing, pero que un porcentaje mucho menor reporte usar de forma consistente la autenticación multifactor. Esta brecha no es una intuición mía: la industria la documenta de forma consistente. El Reporte de Costo de una Violación de Datos 2025 de IBM ubica al phishing como el vector de acceso inicial más común, presente en 16% de los ataques analizados, mientras que el error humano explicó 26% de las violaciones estudiadas (IBM Security, 2025). El Reporte de Investigaciones de Violación de Datos 2026 de Verizon, por su parte, señala que la ingeniería social sigue evolucionando hacia canales de voz y dispositivos móviles, precisamente para sorprender a la víctima en medio de su jornada laboral, cuando baja la guardia (Verizon Business, 2026).

Por grupo poblacional, anticipo que directivos y empresarios muestren una percepción de riesgo más alta que el resto —son blanco típico de ataques dirigidos como el whaling, y probablemente ya han escuchado casos cercanos—, mientras que estudiantes y amas de casa podrían resultar más vulnerables frente al smishing y al phishing genérico, por su alto tiempo de exposición a redes sociales y mensajería instantánea. Si la muestra final incluye suficiente personal de TI (varios de mis contactos en Teams y en el correo de la empresa trabajan en esa área), espero que ese subgrupo puntúe más alto en las ocho técnicas que el resto, lo cual serviría como una especie de grupo de control informal dentro del propio diagnóstico.

5.1 Propuesta de remediación para la comunidad encuestada

Sobre esa base, la acción concreta que propongo para cuando tenga los resultados es diseñar una cápsula breve de concientización —una infografía o un video corto, en la misma línea del material que ya elaboré para el caso Pemex en esta materia— enfocada específicamente en las técnicas que salgan peor reconocidas en la encuesta, con lenguaje accesible y ejemplos cotidianos (el caso del smishing bancario o de las

páginas falsas de streaming que se revisaron en clase) en lugar de terminología técnica que aleja al lector no especializado.

Como segunda acción, de bajo costo y alto impacto, propongo insistir en la adopción de la autenticación multifactor entre quienes contestaron que la conocen pero no la usan, porque es probablemente la defensa más efectiva contra el uso indebido de credenciales obtenidas por ingeniería social. Y como tercera acción, más cultural que técnica, propongo fomentar el hábito de verificar por un canal distinto cualquier solicitud urgente o inusual —una llamada, un correo, un mensaje— antes de actuar, tanto en el entorno familiar como en el laboral, porque casi todas las técnicas evaluadas en este instrumento dependen, en el fondo, de que la víctima actúe rápido y sin confirmar.

6. Conclusiones

Diseñar este instrumento me dejó más claro que la ingeniería social no es un problema que se resuelva solo con tecnología: un firewall no evita que alguien conteste una llamada de un supuesto soporte técnico o escanee un código QR en una mesa de restaurante. El diseño del cuestionario, al separar preguntas de conocimiento y preguntas de percepción, me obligó a pensar la ingeniería social como lo que es: un problema de comportamiento humano bajo presión, no un problema de falta de información técnica.

La difusión en tres canales tan distintos entre sí —un grupo académico de WhatsApp, Microsoft Teams dentro de mi trabajo y un correo a toda la organización— confirma algo que ya sospechaba antes de empezar: el nivel de exposición a estos ataques no depende de la edad o del puesto que alguien tenga, sino de cuánto tiempo pasa esa persona respondiendo mensajes, correos y llamadas de desconocidos, algo que hoy nos ocurre a prácticamente todos por igual. Esa es, para mí, la conclusión más importante de esta primera entrega: el diagnóstico no busca señalar a quién le falta capacitación técnica, sino identificar en qué momento cotidiano de cada perfil poblacional es más probable que baje la guardia, para poder dirigir ahí la concientización de la segunda entrega.

7. Referencias (APA 7)

Bennett, B. (2023). Phishing, vishing, smishing and beyond. NZ Business + Management, 37(2), 36–37.

Hadnagy, C. (2010). Social engineering: The art of human hacking. John Wiley & Sons.

IBM Security. (2025). Cost of a data breach report 2025. IBM. https://www.ibm.com/reports/data-breach

López Torres, J. H., & Torres Buitrago, J. E. (2023). Ingeniería social. Ingeniería Americana, 3(3), 1–9. https://doi.org/10.21803/ingecana.3.3.740

Matecas, A.-R., Kieseberg, P., & Tjoa, S. (2025). Ingeniería social con IA. Future Internet.

Verizon Business. (2026). 2026 data breach investigations report. Verizon. https://www.verizon.com/business/resources/reports/dbir/